

RashtreeyaSikshanaSamithi Trust

RV Institute of Technology and Management®

(Affiliated to VTU, Belagavi)

JP Nagar, Bengaluru – 560076

Department of Electronics and Communication Engineering



Course Name: INTRODUCTION TO CYBER SECURITY

Course Code: 22ETC154/254

I/II Semester

2022 Scheme

Prepared By

Dr. Vikash Kumar

Department of ECE

RV Institute of Technology & Management

Unit IV: Phishing and Identity Theft

Phishing and Identity Theft: Introduction, Methods of Phishing, Phishing Techniques, Spear Phishing, Types of Phishing scams, Phishing toolkits and spy phishing, counter measures, Identity Theft

Methods of Phishing

- 1. Dragnet:** This method involves the use of spammed E-Mails, bearing falsified corporate identification (e.g., corporate names, logos and trademarks), which are addressed to a large group of people- (e.g., customers of a particular financial institution or members of a particular auction site) to websites or pop-up windows with similarly falsified identification. Dragnet phishers do not identify specific prospective victims in advance. Instead, they rely on false information included in an E-Mail to trigger an immediate response by victims - typically, clicking on links in the body of the E-Mail to take the victims to the websites or pop-up windows where they are requested to enter bank or credit card account data or other personal data.
- 2. Rod-and-reel:** In this method, phishers identify specific prospective victims in advance, and convey false information to them to prompt their disclosure of personal and financial data. For example, on the phony webpage, availability of similar item for a better price (i.e., cheaper price) is displayed which the victims may be searching for and upon visiting the webpage, victims were asked for personal information such as name, bank account numbers and passwords, before confirming that the "sale" and the information is available to the phisher easily.
- 3. Lobsterpot:** This method focuses upon use of spoofed websites. It consists of creating of bogus/phony websites, similar to legitimate corporate ones, targeting a narrowly defined class of victims, which is likely to seek out. example of a deceptive URL address linking to a scam website. The phisher places a weblink into an E-Mail message to make it look more legitimate and actually takes the victim to a phony scam site, which appears to be a legitimate website or possibly a pop-up window that looks exactly like the official site. These fake sites are also called "spoofed" websites. Once the netizens is into one of these spoofed sites, he/she might unwittingly send personal information to the con artists. Then they often use your information to purchase goods, apply for a new credit card or otherwise steal your identity.
- 4. Gillnet:** This technique relies far social engineering techniques and phishers introduce Malicious Code into E-Mails and websites. They can, for example, misuse browser functionality by injecting hostile content into another site's pop-up window. Merely by opening a particular E-Mail, or browsing a particular website, netizens may have a Trojan. Horse introduced into their systems.

Phishing Techniques

There are a number of different techniques used to obtain personal information from users. As technology becomes more advanced, the cybercriminals' techniques being used are also more advanced.

To prevent Internet phishing, users should have knowledge of how the bad guys do this and they should also be aware of anti-phishing techniques to protect themselves from becoming victims.

Spear Phishing

While traditional phishing uses a 'spray and pray' approach, meaning mass emails are sent to as many people as possible, **spear phishing** is a much more targeted attack in which the hacker knows which specific individual or organization they are after. They do research on the target in order to make the attack more personalized and increase the likelihood of the target falling into their trap.

Email/Spam

Using the most common phishing technique, the same email is sent to millions of users with a request to fill in personal details. These details will be used by the phishers for their illegal activities. Most of the messages have an urgent note which requires the user to enter credentials to update account information, change details, or verify accounts. Sometimes, they may be asked to fill out a form to access a new service through a link which is provided in the email.

Web Based Delivery

Web based delivery is one of the most sophisticated phishing techniques. Also known as “man-in-the-middle,” the hacker is located in between the original website and the phishing system. The phisher traces details during a transaction between the legitimate website and the user. As the user continues to pass information, it is gathered by the phishers, without the user knowing about it.

Link Manipulation

Link manipulation is the technique in which the phisher sends a link to a malicious website. When the user clicks on the deceptive link, it opens up the phisher's website instead of the website mentioned in the link. Hovering the mouse over the link to view the actual address stops users from falling for link manipulation.

Keyloggers

Keyloggers refer to the malware used to identify inputs from the keyboard. The information is sent to the hackers who will decipher passwords and other types of information. To prevent key loggers from accessing personal information, secure websites provide options to use mouse clicks to make entries through the virtual keyboard.

Trojan

A Trojan horse is a type of malware designed to mislead the user with an action that looks legitimate, but actually allows unauthorized access to the user account to collect credentials through the local machine. The acquired information is then transmitted to cybercriminals.

Malvertising

Malvertising is malicious advertising that contains active scripts designed to download malware or force unwanted content onto your computer. Exploits in Adobe PDF and Flash are the most common methods used in malvertisements.

Session Hijacking

In session hijacking, the phisher exploits the web session control mechanism to steal information from the user. In a simple session hacking procedure known as session sniffing, the phisher can use a sniffer to intercept relevant information so that he or she can access the Web server illegally.

Content Injection

Content injection is the technique where the phisher changes a part of the content on the page of a reliable website. This is done to mislead the user to go to a page outside the legitimate website where the user is then asked to enter personal information.

Phishing through Search Engines

Some phishing scams involve search engines where the user is directed to products sites which may offer low cost products or services. When the user tries to buy the product by entering the credit card details, it's collected by the

phishing site. There are many fake bank websites offering credit cards or loans to users at a low rate but they are actually phishing sites.

Vishing (Voice Phishing)

In phone phishing, the phisher makes phone calls to the user and asks the user to dial a number. The purpose is to get personal information of the bank account through the phone. Phone phishing is mostly done with a fake caller ID.

Smishing (SMS Phishing)

Phishing conducted via Short Message Service (SMS), a telephone-based text messaging service. A smishing text, for example, attempts to entice a victim into revealing personal information via a link that leads to a phishing website.

Malware

Phishing scams involving malware require it to be run on the user's computer. The malware is usually attached to the email sent to the user by the phishers. Once you click on the link, the malware will start functioning. Sometimes, the malware may also be attached to downloadable files.

Ransomware

Ransomware denies access to a device or files until a ransom has been paid. Ransomware for PC's is malware that gets installed on a user's workstation using a social engineering attack where the user gets tricked in clicking on a link, opening an attachment, or clicking on malvertising.

A definition of spear-phishing

Spear-phishing is a targeted attempt to steal sensitive information such as account credentials or financial information from a specific victim, often for malicious reasons. This is achieved by acquiring personal details on the victim such as their friends, hometown, employer, locations they frequent, and what they have recently bought online. The attackers then disguise themselves as a trustworthy friend or entity to acquire sensitive information, typically through email or other online messaging. This is the most successful form of acquiring confidential information on the internet, accounting for 91% of attacks.

How does spear-phishing work

The act of spear-phishing may sound simple, but spear-phishing emails have improved within the past few years and are now extremely difficult to detect without prior knowledge on spear-phishing protection. Spear-phishing attackers target victims who put personal information on the internet. They might view individual profiles while scanning a social networking site. From a profile, they will be able to find a person's email address, friends list, geographic location, and any posts about new gadgets that were recently purchased. With all of this information, the attacker would be able to act as a friend or a familiar entity and send a convincing but fraudulent message to their target. To increase success rates, these messages often contain urgent explanations on why they need sensitive information. Victims are asked to open a malicious attachment or click on a link that takes them to a spoofed website where they are asked to provide passwords, account numbers, PINs, and access codes. An attacker posing as a friend might ask for usernames and passwords for various websites, such as Facebook, so that they would be able to access posted photos. In reality, the attackers will use that password, or variations of it, to access different websites that have confidential information such as credit card details or Social Security Numbers. Once criminals have gathered enough sensitive information, they can access bank accounts or even create a new identity using their victim's information.

Phishing toolkits and Spying:

A Phishing toolkit is a set of scripts/programs that allows a phisher to automatically set up Phishing websites that spoof the legitimate websites of different brands including the graphics (i.e., images and logos) displayed on these websites. Phishing toolkits are developed by groups or individuals and are sold in the underground economy. These sophisticated kits are typically difficult to obtain, are quite expensive, and are more likely to be purchased and used by well-organized groups of phishers, rather than average users.

Phishers use hypertext preprocessor (PHP) to develop the Phishing kits. PHP is a general purpose scripting language that was originally designed for web development of dynamic webpages. PHP code is embedded into the HTML source script and interpreted by a web server with the help of a PHP processor module.

Most of the Phishing kits are advertised and distributed at no charge and usually these Phishing kits- also called DIY (Do It Yourself) Phishing kits- may hide backdoors through which the phished information is sent to recipients (may be to the authors of Phishing kits) other than the intended users.

Following are few examples of such toolkits:

- 1. Rock Phish:** It is a Phishing toolkit popular in the hacking community since 2005. It allows non-techies to launch Phishing attacks. The kit allows a single website with multiple DNS names to host a variety of phished webpages, covering numerous organizations and institutes.
- 2. Xrenoder Trojan Spyware:** It resets the homepage and/or the search settings to point to other websites usually for commercial purposes or porn traffic.
- 3. Cpanel Google:** It is a Trojan Spyware that modifies the DNS entry in the host's file to point to its own website. If Google gets redirected to its website, a netizen may end up having a version of a website prepared by the phisher.

Phishing Countermeasures

1. Update Email Policies.

The FBI warned of a 270% increase in CEO scams, also known as BEC frauds, in 2015. This situation is no better in 2016 and organizations thought as unsusceptible to attack are now in fraudsters' crosshairs.

To gain company insight, cybercriminals harvest personal information and learn business processes. Once armed with this data, they target carefully selected employees with a spear-phishing email designed to obtain access to confidential company information or transfer money into an unknown account.

One recent example involved Ubiquiti Networks' finance department, which transferred \$46.7 million into an overseas account held by external third parties.

Agari suggested organizations must introduce policies that ensure that no one person or single email can authorize transactions. There also needs to be a mixture of communication channels verifying requests for confidential or financial information.

2. Plan for ID Theft After a Data Breach.

Over the last year, Agari witnessed a trend in spear-phishing attacks aimed at stealing employee payroll information. Hackers use the accessed confidential information to facilitate a variety of frauds. For example: the Snapchat messaging app made headlines when it's payroll department handed over confidential information on current and former employees to a scammer impersonating the CEO.

ID theft often follows data breaches. Organizations need to plan for the worst-case scenario with a post-breach response plan in place.

3. Regular OS Updates and Backups.

On both the enterprise and consumer side, ransomware is becoming a steadily growing form of malware that infects a machine and renders it unusable until it is either unlocked or data decrypted after paying the ransom.

Most ransomware threats hinge on two factors: tricking people into clicking on malicious content, usually email attachments, and banking on devices not having advanced threat protection.

The Hollywood Presbyterian Medical Center had computers taken hostage by the Locky ransomware strain, which Forbes claimed infected approximately 90,000 systems per day. After being offline for a week, officials eventually paid \$17,000 in bitcoin to regain access to patient records.

Agari suggested operating systems, firmware, software and applications need regular patching, updating and backing up to limit the vulnerabilities available for criminals to exploit. Organizations should invest in cyberinsurance to enable a full recovery.

4. Implement Message Authentication.

Consumers reportedly receive up to 20 phishing emails a month and it remains one of the most common, and successful, scamming methods. Fraudsters increasingly target specific individuals with spoofs feigning to be from government departments, banks and major brands. The Agari report stated, “It’s becoming progressively difficult for consumers to distinguish between mimics and genuine correspondence.”

Agari recommended businesses must protect their brand reputation and restore trust in the inbox. Any organization that relies on email to communicate with its customers, citizens or members needs to implement the Domain-based Message Authentication Reporting and Conformance standard in order to help prevent email spoofing. DMARC provides businesses with threat intelligence whenever somebody attempts to spoof their email addresses.

5. Increase Collaboration Efforts.

Many hackers rely on high volumes of email communication to provide a new attack window of opportunity. Evidence emerged that sophisticated phishing scams aim at diverse targets such as political candidates and industrial controls companies. Symantec revealed a Trojan called Lozaik, masquerading as an Excel spreadsheet, targeted workers in the energy industry across the UAE, Kuwait, Saudi Arabia, United States, United Kingdom, and Uganda.

Hacktivisim countermeasures include greater collaboration and information sharing between public and private sectors. Having a multi-layered approach to security practices also puts organizations in a better position to mitigate attacks and reduce the impact of any breaches.

Identity Theft (ID Theft)

- This term is used to refer to fraud that involves someone pretending to be someone else to steal money or get other benefits.
 - ID theft is a punishable offense under the Indian IT Act (Section 66C and Section 66D).
 - The statistics on ID theft proves the severity of this fraud and hence a non-profit organization was found in the US, named as **Identity Theft Resource Center (ITRC)**, with the objective to extend the support to the society to spread awareness about this fraud.
 - Federal Trade Commission (FTC) has provided the statistics about each one of the identity fraud mentioning prime frauds presented below.
1. **Credit card fraud (26%):**
 2. **Bank fraud (17%):** Besides credit card fraud, cheque theft and Automatic Teller Machines (ATM) pass code theft have been reported that are possible with ID theft
 3. **Employment fraud (12%):** In this fraud, the attacker borrows the victim's valid SSN to obtain a job.
 4. **Government fraud (9%):** This type of fraud includes SSN, driver license and income tax fraud.
 5. **Loan fraud (5%):** It occurs when the attacker applies for a loan on the victim's name and this can occur even if the SSN does not match the name exactly.

It is important to note the various usage of ID theft information.

1. 66% of victims' personal information is used **to open a new credit account** in their name.
2. 28% of victims' personal information is used **to purchase cell phone service**.
3. 12% of victims end up having **warrants issued in their name** for financial crimes committed by the identity thief.

Personally Identifiable Information (PII)

The fraudsters attempt to steal the elements mentioned below, which can express the purpose of distinguishing individual identity:

1. Full name;
2. national identification number (e.g., SSN);
3. telephone number and mobile phone number;
4. driver's license number;
5. credit card numbers;
6. digital identity (e.g., E-Mail address, online account ID and password);
7. birth date/birth day;
8. birthplace;
9. face and fingerprints.

The information can be further classified as

- a. non-classified and
- b. classified.

1. Non-classified information

- **Public information:**
- **Personal information:**
- **Routine business information:**
- **Private information:**

2. Classified information

- **Confidential:** Information that requires protection and unauthorized disclosure could damage national security (e.g., information about strength of armed forces and technical information about weapons).
- **Secret:** Information that requires substantial protection and unauthorized disclosure could seriously damage national security (e.g., national security policy, military plans or intelligence operations).
- **Top secret:** Information that requires the highest degree of protection and unauthorized disclosure could severely damage national security (e.g., vital defense plans and cryptologic intelligence systems).

ID theft fraudsters and/or industrial/international spies target to gain the access to private, confidential, secret and top secret information.

Types of Identity Theft

1. Financial identity theft;
2. criminal identity theft;
3. identity cloning;
4. business identity theft;
5. medical identity theft;
6. synthetic identity theft;
7. child identity theft.



Techniques of ID Theft

1. Human-based methods:

- *Direct access to information:*
- *Dumpster diving:*
- *Theft of a purse or wallet:*
- *Mail theft and rerouting:*
- *Shoulder surfing:*
- *Dishonest or mistreated employees:*
- *Telemarketing and fake telephone calls:*

2. Computer-based technique:

- *Backup theft:*
- *Hacking, unauthorized access to systems and database theft:*
- *Phishing:*
- *Pharming:*
- *Hardware:*